

Sri Lanka Institute of Information Technology



Enterprise Standards for Information Security - IE3102

Asset Registry

IT23269484 – T. H. Ranasinghe

1. Introduction

An Information Security Management System (ISMS) cannot exist without clarity on what needs protection. ISO/IEC 27001:2022, through Clause 8 (“Operation”) and Annex A controls A.5 and A.8, explicitly requires organizations to maintain a complete inventory of information assets. The Asset Registry is thus the cornerstone of operational governance, ensuring traceability, accountability, and continual improvement of security controls.

An asset in ISO terminology is anything that has value to the organization. This includes data, software, hardware, facilities, human resources, and intellectual property. Corporate information security is not limited to technical tools but is a comprehensive approach to managing company assets and information as a whole. An Asset Registry, therefore, translates that philosophy into a practical tool for evidence-based management of information resources within an ISMS.

2. Purpose and Relevance

The purpose of an Asset Registry is to identify, classify, and control assets so that their value and risk exposure are explicitly known. ISO 27001 Clause 8 links this process to operational planning, while Annex A.8 provides specific controls for asset ownership and acceptable use.

Key objectives include:

- **Comprehensive Identification:** Ensure that every information asset within the ISMS scope is registered and traceable.
- **Ownership and Accountability:** Each asset has a designated owner responsible for its security and maintenance.
- **Classification and Valuation:** Define confidentiality levels (Public, Internal, Confidential, Restricted) and link to business impact criteria.
- **Risk Linkage:** Connect each asset to its relevant threats and Annex A controls to facilitate risk treatment plans.
- **Continuous Monitoring:** Support the Plan–Do–Check–Act (PDCA) cycle as advocated for ongoing ISMS improvement.

3. Scope and Structure of the Registry

The scope of the Asset Registry encompasses digital and non-digital resources that support information processing, including servers, databases, software applications, networks, portable devices, records, and human assets. Each asset entry must capture core metadata to enable governance and audit traceability.

Field	Description
Asset ID	Unique identifier for traceability.
Asset Name/Description	Title or function of the asset.
Asset Type	Hardware, Software, Data, Human, Facility.
Owner/Custodian	Person accountable for security and maintenance.
Classification	Public, Internal, Confidential, Restricted.
Associated Risks	Threats and vulnerabilities from the Risk Register.
Annex A Control Link	Relevant control.
Location	Physical or logical location of the asset.
Backup/Retention	Backup frequency and data retention schedule.
Review Date	Next scheduled review for accuracy.

4. Link to Risk-Based Approach

Effective information security relies on a continuous risk management cycle. Each asset is a potential source of risk and must be evaluated against the confidentiality, integrity, and availability (CIA) model. By integrating asset data with the Risk Register, the organization achieves risk-based decision making and ensures that control selection is justifiable. For instance, if a database contains personal data, risks such as data breach or unauthorized access will map to controls A.5.1 (Information Security Policy) and A.9.4 (System Access Control).

5. Integration with ISO Management Frameworks

ISO 27001:2022 aligns with global cybersecurity frameworks like the NIST Cybersecurity Framework and includes new controls such as information security for cloud services and data masking. The Asset Registry must account for these dimensions by flagging cloud and IoT assets separately, ensuring that their associated controls are monitored. This approach connects ISO and NIST functions

(Identify → Protect → Detect → Respond → Recover) to each recorded asset.

6. Example Excerpt from the Registry

	A	B	C	D	E	F	G	H
1	Asset ID	Asset Name	Type	Owner	Classification	Associated Risk	Annex A Control	Review Date
2	AR-001	Finance Server	Hardware	IT Manager	Restricted	Data theft, Ransomware	A.5.1.1, A.8.1.2, A.13.2.3	Jun-25
3	AR-004	HR Database	Data	HR Head	Confidential	Unauthorized access	A.9.2.3, A.18.1.4	May-25
4	AR-007	Cloud Backup System	Software/ Cloud	ISMS Manager	Internal	Cloud service breach	A.5.23 (Cloud Security), A.12.3.1	Jul-25

This template ensures consistency and auditability for each asset and forms the primary evidence for Clause 8 operations.

7. Maintenance and Version Control

The Asset Registry is a living document. It should be reviewed semi-annually or whenever there is a technological or organizational change. Old versions must be retained for audit purposes. Changes are logged using version control methods. Each update must be approved by the ISMS Manager.

Common problem in ISMS implementation is the informal treatment of documentation. A controlled Asset Registry addresses this weakness by making documentation a strategic instrument of security management rather than a bureaucratic requirement.

8. Inter-Document Integration

The Asset Registry interacts closely with the Statement of Applicability (SoA) and the Risk Treatment Plan (RTP):

- Registry → SoA: Defines which assets require which controls.
- SoA → RTP: Confirms selected controls and rationale.
- RTP → Registry: Feeds back results of risk treatment to update asset status.

9. Governance and Responsibilities

Role	Responsibilities in Asset Registry Management	Review Frequency
ISMS Manager	Ensure registry accuracy and policy compliance.	Every 6 months
Asset Owners	Update asset records after acquisition or disposal.	Ongoing
Risk Owner	Verify risk linkage and Annex A control mapping.	Quarterly
Internal Auditor	Audit registry completeness and effectiveness.	Annually

10. Challenges and Solutions

Common challenges identified by Aleksandrova et al. (2020):

- Incomplete inventory due to decentralized departments.
- Outdated asset information after rapid technological changes.
- Resistance to documentation updates.

Proposed solutions:

- Centralized digital Asset Registry platform linked to Change Management System.
- Mandatory review triggers upon procurement and decommissioning.
- Training and awareness to highlight the value of asset governance.

11. Benefits of an Effective Asset Registry

The updated ISO/IEC 27001:2022 encourages digital trust through asset-centric controls such as configuration management, monitoring activities, and data deletion. A well-maintained Asset Registry enables these benefits:

- Enhanced visibility of information flows across systems.
- Faster incident response and root-cause analysis.
- Simplified audits and certification renewals.
- Cost efficiency through reduction of duplicate assets.
- Support for strategic decisions on risk mitigation and investment.

12. Conclusion

The Asset Registry is a pillar of ISO/IEC 27001:2022 compliance. It provides empirical proof that an organization understands its assets, manages their risks, and implements controls accordingly. By applying risk-based management and integrating registry updates into the PDCA cycle, organizations demonstrate maturity in information security governance. The registry is not a static record but a dynamic management instrument that connects policies, controls, and continuous improvement of the foundation of sustainable information security management.

13. References

- Aleksandrov, Mark N. and Vasiliev, Victor A. and Aleksandrova, Svetlana V. (2021). Implementation of the Risk-based Approach Methodology in Information Security Management Systems. 2021 International Conference on Quality Management, Transport and Information Security, Information Technologies (IT&QM&IS), (pp. 137-139).
- Guo, Huaqun and Wei, Meng and Huang, Ping and Chekole, Eyasu Getahun. (2021). Enhance Enterprise Security through Implementing ISO/IEC 27001 Standard. 2021 IEEE International Conference on Service Operations and Logistics, and Informatics (SOLI).
- (Third edition 2022-10). ISO/IEC 27001:2022 - Information Security Management Standards, International Organization for Standardization. INTERNATIONAL STANDARD.
- Malatji, Masike. (2023). Management of enterprise cyber security: A review of ISO/IEC 27001:2022. 2023 International Conference On Cyber Management And Engineering (CyMaEn).